

Development Security & Data Privacy Manual

EIA Highly Confidential

Copyright Notice ©Copyright 2025
All rights reserved. This is the property of the Company. The contents of this document, either in full or in part, are not allowed to be copied in any form or used by anyone outside the Company unless specifically authorized in writing by the document owner or other authorized representative of the Company.

UPDATING
The document owner will issue updates to all registered holders of each "hard copy" of this document. The registered holder will be responsible for updating the document by replacing pages or sections as instructed. Printed copies will automatically assume "unmaintained" status.

Document Control

Version Control

	Name	Designation	Date	Signature
Initiated by	Mohannad Elkhidir	Senior IT Security & Governance Specialist	30-Sep-2026	
Endorsed by				
Approved by	Samer Awajan	Chief Technology Officer		

Version History

Amendment No.	Section No.	Date of Revision	Details of Amendments	Originated By	Remarks
00	NA	01-Oct-2026	Initial draft of the manual created for internal review. Consolidates the Information Security Policy, GIS DevSecOps & Secure Development Standard and UAE IA Regulation requirements for GIS vendors.	Information Security Department	

Document Information

Item	Value
Document owner	Director of Information Security, 7X Group
Prepared by	Information Security Department (IT CG)
Classification	Restricted
Review cycle	At least annually, and after any major incident, regulatory change or policy revision
Parent policy	7X Information Security Policy (Amendment 07, 31-Jul-2026)
Source standards	7X Information Security Policy; GIS Project DevSecOps & Secure Development Standard; ISMS Minimum Security Baseline [content pending]; UAE Information Assurance Regulation v1.1

Abbreviations

Abbreviation	Term
ARC	Audit and Risk Committee
API	Application Programming Interface
ASVS	OWASP Application Security Verification Standard
CI/CD	Continuous Integration / Continuous Delivery
CIS	Center for Internet Security
CVSS	Common Vulnerability Scoring System
DAST	Dynamic Application Security Testing
EDR	Endpoint Detection and Response
ETL	Extract, Transform, Load
GIS	Geographic Information System
HSM	Hardware Security Module
IaC	Infrastructure as Code
ISMS	Information Security Management System
MFA	Multi-Factor Authentication
OGC	Open Geospatial Consortium
OWASP	Open Worldwide Application Security Project
PAM	Privileged Access Management
PDPL	UAE Personal Data Protection Law (Federal Decree-Law No. 45 of 2021)
PM	Project Manager
RBAC	Role-Based Access Control
SAMM	OWASP Software Assurance Maturity Model
SAST	Static Application Security Testing
SBOM	Software Bill of Materials
SCA	Software Composition Analysis
SIEM	Security Information and Event Management
SSO	Single Sign-On
SSRF	Server-Side Request Forgery
TDRA	Telecommunications and Digital Government Regulatory Authority
TLS	Transport Layer Security
UAE IAR	UAE Information Assurance Regulation v1.1
UAT	User Acceptance Testing
VAPT	Vulnerability Assessment and Penetration Testing
VDI	Virtual Desktop Infrastructure
WAF	Web Application Firewall
XSS	Cross-Site Scripting
XXE	XML External Entity

Definitions

Term	Definition
Business Owner	The Company Head of Department who owns the information and approves access to it.
Company	7X Group, including all subsidiaries, affiliates and group entities.
Company Security Focal Point	The Information Security Department contact assigned to the engagement.
Feature service / Map service	A web service that serves vector features (editable or read-only) or rendered map images.
Geocoding / Reverse geocoding	Converting an address to coordinates, or coordinates to an address.
Geospatial / Location data	Any data with a spatial reference: coordinates, addresses, geometries, routes, GPS tracks, imagery and geotagged photos.
OGC services	Open Geospatial Consortium standards: WMS (map images), WMTS (map tiles), WFS (vector features), WFS-T (transactional, i.e. editable WFS), WCS (coverages/rasters) and WPS (processing).
Personal data	Any data that identifies or can identify a natural person, directly or indirectly, as defined in the PDPL. A home address or a repeated GPS track is personal data.
Precision reduction	Lowering coordinate accuracy (e.g. rounding decimals, snapping to a grid or aggregating to an area) to reduce identifiability.
Production data	Any real Company or customer data, including copies, extracts, backups and tile caches derived from it.
Security Exception Register	The central register, owned by the Director of Information Security, of all approved deviations from policy.
Sensitive personal data	Personal data revealing, among others, health, biometrics, religion, criminal records or family status, as defined in the PDPL.
Spatial database	A database with spatial types and functions, e.g. PostgreSQL/PostGIS, Oracle Spatial, SQL Server spatial or an Esri enterprise geodatabase.
Tile cache	Pre-rendered map images or vector tiles stored for fast delivery. A cache holds a copy of the underlying data.
Vendor	Any external party contracted to deliver GIS work for the Company, including its subcontractors and personnel.
Vendor Security Lead	The named vendor individual accountable for compliance with this manual on an engagement (Section 11.2).

Table of Contents

1 PURPOSE, OBJECTIVES AND SCOPE 8
1.1 Purpose 8
1.2 Objectives 8
1.3 Scope 8
1.4 How to Read this Manual 8
1.5 Precedence 8
2 GOVERNANCE, ROLES AND SECURITY EXCEPTIONS 10
2.1 Security Principles 10
2.2 Roles 10
2.3 Secure SDLC Gates 10
2.4 Security Exceptions 10
3 DEVELOPMENT ENVIRONMENT SECURITY 12
3.1 Environment Segregation 12
3.2 Developer Workstations 12
3.3 Hardening of Development and Test Servers 12
3.4 Remote Access 12
4 IDENTITY AND ACCESS MANAGEMENT 13
4.1 Vendor Personnel Accounts 13
4.2 Authentication of People 13
4.3 Authentication in Delivered GIS Applications 13
4.4 Authorisation 13
4.5 Privileged Access 14
4.6 Service Accounts and Machine Identities 14
4.7 Access Reviews 14
5 DATA SECURITY, HANDLING AND PRIVACY 15
5.1 Classification Levels 15
5.2 Handling Rules by Level 15
5.3 Encryption and Key Management 15
5.4 Personal Data and Privacy by Design 16
5.5 Non-Production Data 16
5.6 Data Residency and Transfer 16
5.7 Retention and Disposal 17
6 CODE SECURITY AND SECURE DEVELOPMENT PRACTICES 18
6.1 Threat Modelling 18
6.2 Input Validation 18

6.3 Output Encoding and Client Security 18
6.4 Secrets Management 18
6.5 Third-Party Components and Dependencies 19
6.6 API and Service Security 19
6.7 Application Security Logging 19
6.8 AI-Assisted Coding 19
7 VERSION CONTROL, CI/CD AND DEPLOYMENT SECURITY 20
7.1 Repositories 20
7.2 Branch Protection 20
7.3 Code Review 20
7.4 Mandatory Pipeline Security Gates 20
7.5 Pipeline and Release Integrity 21
7.6 Hosting and Internet-Facing Deployment 21
7.7 Audit Logging of the Delivery Chain 21
8 SECURITY TESTING AND VULNERABILITY MANAGEMENT 22
8.1 Required Testing 22
8.2 Rules of Engagement 22
8.3 Severity and Remediation Deadlines 22
8.4 Internet-Facing Systems 22
8.5 Patching 23
8.6 Vulnerability Disclosure by the Vendor 23
9 COMPLIANCE AND REGULATORY REQUIREMENTS 24
9.1 Applicable Laws, Regulations and Standards 24
9.2 UAE Information Assurance Regulation Mapping 24
9.3 Personal Data Obligations 25
9.4 Audit Trails and Retention 25
9.5 Audit and Compliance Monitoring 25
9.6 Licensing and Intellectual Property 25
10 INCIDENT RESPONSE AND ESCALATION 26
10.1 What Must Be Reported 26
10.2 Reporting Deadlines and Severity 26
10.3 Vendor Actions During an Incident 26
10.4 Regulatory Notification 27
10.5 Escalation 27
11 VENDOR RESPONSIBILITIES AND ACCOUNTABILITY 28
11.1 Contractual Standing 28
11.2 Vendor Security Lead 28

11.3 Onboarding of Personnel 28
11.4 Subcontractors 28
11.5 Reporting and Evidence 28
11.6 Handover and Exit 28
11.7 Consequences of Non-Compliance 28
12 APPROVED TOOLS AND TECHNOLOGY RESTRICTIONS 30
12.1 General 30
12.2 Approved Tool Categories 30
12.3 Prohibited Without Explicit Written Approval 31
13 VENDOR FREQUENTLY ASKED QUESTIONS 32
ANNEX A – GIS GO-LIVE SECURITY CHECKLIST 33
ANNEX B – OPEN ITEMS TO CONFIRM BEFORE ISSUE 34

7X – Development Security & Data Privacy Manual

1 PURPOSE, OBJECTIVES AND SCOPE

This manual is the mandatory security and data privacy standard for every vendor that designs, builds, tests, deploys or maintains Geographic Information System (GIS) solutions for 7X Group. It is not guidance: where it says "must", non-compliance is a contractual breach.

1.1 Purpose

1.1.1 This manual sets the minimum security and privacy controls for GIS development across the full lifecycle: environment setup, design, coding, build, test, release, operation, maintenance and decommissioning.

1.1.2 It replaces all prior ad-hoc security guidance issued to GIS vendors. Earlier emails, slide decks or meeting notes on security have no standing once this manual is issued.

1.2 Objectives

Vendors must deliver GIS solutions that:

(i) Protect the confidentiality, integrity and availability of Company information, including location data about customers, employees, couriers, facilities and assets.
(ii) Process personal data lawfully under the PDPL.
(iii) Meet OWASP ASVS Level 2 as a minimum for every application and API.
(iv) Pass every security gate in the CI/CD pipeline and the go-live checklist (Annex A) before production.
(v) Produce auditable evidence of every control, retained for the periods in Section 9.4.

1.3 Scope

1.3.1 **Organisations.** This manual applies to all 7X Group entities for which the vendor works, including EMX, Emirates Post, Instant Cash (IC), Waslah and NXN [TO CONFIRM entities in scope].

1.3.2 **People.** It binds the vendor, its employees, contractors and subcontractors at any tier who access Company information, systems, code or environments, wherever they are located.

1.3.3 **Systems.** It covers all GIS components delivered or maintained for the Company, including:

- desktop and web GIS clients, mobile field-data apps and map viewers;
- GIS servers and map, feature, tile, geocoding, routing and geoprocessing services;
- spatial databases, file-based datasets (Shapefile, GeoPackage, GeoJSON, KML, GML) and imagery;
- APIs, integrations, ETL jobs, scripts and Infrastructure as Code (IaC);
- CI/CD pipelines, repositories, build agents, containers and artefact stores.

1.3.4 **Deployment models.** It applies to on-premises, private cloud and public cloud deployments, and to Internet-facing and internal applications. Internet-facing applications that process sensitive data carry the additional controls in Sections 7.6 and 8.4.

1.3.5 **Out of scope.** Commercial terms, service levels unrelated to security, and GIS cartographic or functional standards.

1.4 How to Read this Manual

1.4.1 **Must / required / will** are mandatory. **Must not / prohibited / will not** are forbidden. There is no "should" in this manual.

1.4.2 Requirements are numbered (for example, 4.3.2). Vendors must cite these numbers in evidence packs, exception requests and audit responses.

1.4.3 Where this manual and a contract conflict, the stricter requirement applies. Where a requirement cannot be met, the vendor must raise an exception under Section 2.4 **before** deviating.

1.4.4 Values marked **[TO CONFIRM]** are draft defaults awaiting confirmation by the Information Security Department. They are listed in Annex B and will be removed before issue.

1.5 Precedence

In case of conflict, the following order of precedence applies:

(i) Applicable UAE law and regulation.

(ii) The 7X Information Security Policy and the ISMS Minimum Security Baseline.
(iii) This manual.
(iv) Project-specific security requirements agreed in writing with the Information Security Department.

2 GOVERNANCE, ROLES AND SECURITY EXCEPTIONS

2.1 Security Principles

Every design and implementation decision must follow these principles: shift security left, secure by design, privacy by design, zero trust, least privilege, defence in depth, automation first and continuous monitoring. "We will harden it later" is not an accepted position.

2.2 Roles

Role	Responsibilities under this manual
Director of Information Security (Company)	Owns this manual, approves security sign-off, owns the Security Exception Register and incident response.
Company Security Focal Point	Day-to-day security contact; reviews threat models, test results and evidence packs.
Business Owner (Company)	Classifies the data, approves access, accepts residual risk within delegated authority.
IT Operations (Company)	Operates production infrastructure, identity, SIEM and PAM; grants and revokes access.
Vendor Account Executive	Accountable for the vendor's contractual compliance and resourcing of security work.
Vendor Security Lead	Accountable for day-to-day compliance: evidence, gates, remediation, incident reporting.
Vendor developers, testers, DevOps engineers	Follow every requirement in this manual for the work they perform.

2.2.1 The vendor must name a Vendor Security Lead and a deputy in writing before any access is granted.

2.2.2 Accountability is not transferred by delegation. Work done by a subcontractor is treated as work done by the vendor.

2.3 Secure SDLC Gates

2.3.1 The vendor must complete these activities, with evidence, for every engagement:

(i) **Security requirements** defined and agreed before development starts, including data classification (Section 5.1).
(ii) **Threat model** for the initial design and for every major release (Section 6.1).
(iii) **Security acceptance criteria** written into user stories.
(iv) **Architecture security review** by the Company Security Focal Point before build.
(v) **Pipeline gates passed** for every release (Section 7.4).
(vi) **Security testing** completed and findings closed to the thresholds in Section 8.
(vii) **Security sign-off** issued in writing by the Information Security Department before production deployment.

2.4 Security Exceptions

2.4.1 Any deviation from this manual requires an approved exception **before** the deviation is implemented. An exception is not valid until it appears in the Security Exception Register.

2.4.2 The vendor must submit the request through the Company Security Focal Point, stating: the requirement number; the systems, data and users affected; business justification; likelihood, impact and residual risk rating; compensating controls; the proposed Company risk acceptor; and an expiry date.

2.4.3 Approval authority depends on residual risk:

Residual risk	Approver	Maximum duration
Low	Director of Information Security	12 months
Medium	Director of Information Security with the Business Owner	12 months
High / Critical	PM, on recommendation of the Director of Information Security, with Risk Management concurrence	6 months

2.4.4 Exceptions lapse automatically on expiry. A renewal needs a fresh assessment and approval, and no more than two renewals are allowed without a documented remediation plan and target closure date.

2.4.5 No exception will be granted where it would breach UAE law, a regulation or a binding contract. Example: no exception can permit Secret or personal data to be hosted outside approved locations without the legal basis required by Section 9.3.

2.4.6 The requesting vendor and the approving Business Owner remain jointly accountable for anything done under the exception.

3 DEVELOPMENT ENVIRONMENT SECURITY

3.1 Environment Segregation

3.1.1 The vendor must keep four logically and network-separated environments: **DEV**, **TEST** (SIT/QA), **UAT** and **PROD**. Environments must not share databases, service accounts, secrets, storage buckets or tile caches.

3.1.2 Traffic from DEV, TEST or UAT to PROD is prohibited, except for approved release pipelines and approved monitoring flows.

3.1.3 Environment names must appear in every resource name so that no resource is ambiguous. Required pattern: `<entity>-<system>-<env>-<component>-<nn>`, lower case.

Correct	Incorrect
`emx-gisportal-uat-postgis-01`	`gis-db-new`
`waslah-routing-prod-api-02`	`prod2-test`

3.1.4 Developers must not have standing access to PROD. Production changes are made only through the pipeline (Section 7) or through break-glass access under Section 4.5.

3.2 Developer Workstations

3.2.1 Development on Company code or data must be performed on one of:

- a Company-issued laptop;
- a Company-managed virtual desktop (VDI) or jump host [TO CONFIRM which access model applies]; or
- a vendor device that the Company has approved in writing and that meets 3.2.2.

3.2.2 Any device used must have, at all times: full-disk encryption; Company-approved EDR or antimalware with real-time scanning and tamper protection; a supported, fully patched operating system; a host firewall; screen lock after 10 minutes of inactivity [TO CONFIRM]; and no local administrator rights for day-to-day use.

3.2.3 Company code and data must not be stored on personal devices, personal cloud storage (e.g. personal OneDrive, Google Drive, Dropbox) or removable media. USB storage is prohibited unless Company-issued and encrypted.

3.2.4 Local copies of datasets are limited to the synthetic or masked data allowed in Section 5.5. Local copies of production data are prohibited.

3.3 Hardening of Development and Test Servers

3.3.1 DEV, TEST and UAT servers, containers and databases must be built from the same hardened baseline as PROD (CIS Benchmark aligned, per the ISMS Minimum Security Baseline). A lower-security environment is a common path into production.

3.3.2 Default and vendor-supplied accounts must be removed or disabled before an asset is connected to any Company network. Where technically required, they must be assigned a named owner and a changed password. Examples: GeoServer `admin/geoserver`, PostgreSQL `postgres` with a default or empty password, ArcGIS Server primary site administrator left with its installation password, Tomcat manager.

3.3.3 GIS administration consoles must never be reachable from the Internet in any environment. This includes GeoServer web admin, ArcGIS Server Manager, ArcGIS Portal admin, PostGIS/pgAdmin, Tomcat manager and container orchestration dashboards.

3.4 Remote Access

3.4.1 Vendor access to Company environments is permitted only through the Company-approved remote access path with MFA (Section 4.2). Personal VPNs, remote-desktop tools (e.g. AnyDesk, TeamViewer) and tunnelling tools (e.g. ngrok, reverse SSH tunnels) are prohibited.

3.4.2 Access from outside the UAE requires prior written approval from the Information Security Department [TO CONFIRM whether offshore development is allowed].

3.4.3 Remote sessions to UAT and PROD must be brokered and recorded through PAM.

4 IDENTITY AND ACCESS MANAGEMENT

All access follows "Need to Know, Need to Do": the minimum rights for the task, for the minimum time, approved before use.

4.1 Vendor Personnel Accounts

4.1.1 Every person must have a unique, named account. Shared, generic or team accounts are prohibited (e.g. `vendor-dev`, `gisadmin`, `testuser`).

4.1.2 No account is created before written approval by the Business Owner and completion of the vendor onboarding in Section 11.3.

4.1.3 Every vendor account has an expiry date no later than the end of the contract or work order, and no longer than 6 months without re-approval [TO CONFIRM].

4.1.4 The Vendor Security Lead must notify the Company Security Focal Point **within 1 working day** when any person leaves the engagement, changes role or no longer needs access [TO CONFIRM]. Access will be revoked on or before their last working day.

4.1.5 On exit, the person must return all Company assets (laptops, tokens, access cards) and delete any Company data held, with written confirmation from the Vendor Security Lead.

4.2 Authentication of People

4.2.1 MFA is mandatory for all vendor access to Company systems: remote access, code repositories, CI/CD, cloud consoles, GIS administration and any PROD or UAT access. SMS one-time codes are not acceptable where an authenticator app or hardware key is available.

4.2.2 Passwords must meet the Company Password Policy as a minimum: at least 8 characters with upper case, lower case, numbers and symbols; no dictionary words or personal information; no reuse of the last 3 passwords; change at least every 90 days; initial passwords changed at first logon. For vendor and privileged accounts, the minimum length is 14 characters [TO CONFIRM against Minimum Security Baseline].

4.2.3 Credentials must never be shared, written down, sent by email or chat, or saved in browsers or application "remember password" features.

4.3 Authentication in Delivered GIS Applications

4.3.1 Applications for Company staff must use single sign-on with the Company identity provider over OpenID Connect or SAML 2.0 [TO CONFIRM identity provider, e.g. Microsoft Entra ID]. Local application accounts are prohibited unless approved by exception.

4.3.2 Customer-facing applications must meet ASVS Level 2 authentication controls, including MFA for any privileged or administrative function.

4.3.3 API authentication must use OAuth 2.0 / OIDC tokens or mutual TLS. Tokens must be short-lived (access tokens 60 minutes or less [TO CONFIRM]) and validated server-side for signature, issuer, audience and expiry.

4.3.4 Tokens and API keys must never be sent in URL query strings. This is a common GIS failure: ArcGIS `?token=`, basemap `?key=` and WMS `&apikey=` parameters are recorded in proxy logs, browser history and tile caches. Use the `Authorization` header instead.

4.3.5 Sessions must be invalidated on logout and after 15 minutes of inactivity for administrative functions [TO CONFIRM]. Cookies must be `Secure`, `HttpOnly` and `SameSite=Lax` or stricter.

4.4 Authorisation

4.4.1 Access must be role-based (RBAC) and enforced **on the server**. Hiding a layer, field or button in the map client is not access control. The service itself must refuse the request.

4.4.2 GIS authorisation must be applied at three levels:

Level	Requirement	Example
Service / layer	Each map, feature, tile and OGC service has an explicit role list. No anonymous access unless the Business Owner has classified the layer as Public.	Customer delivery points layer visible to the Operations role only.
Feature (row)	Users see only the features their role and entity allow, enforced in the database or service.	PostGIS row-level security restricting Instant Cash branch data to IC users.
Attribute (field)	Personal and sensitive attributes are excluded from services unless the role needs them.	Courier name and phone excluded from the public tracking layer.

4.4.3 Every request that references an object ID (e.g. `OBJECTID`, `featureId`, `parcelId`) must check that the caller may access that object, to prevent insecure direct object reference.

4.4.4 Editing must be disabled by default. WFS-T and feature-service editing (create, update, delete) are enabled only for named roles that need them.

4.5 Privileged Access

4.5.1 Administrative access to servers, databases, GIS platforms and cloud consoles must be performed through PAM, with session recording and time-limited checkout.

4.5.2 Privileged accounts must be separate from everyday accounts (e.g. `a.name` for daily work, `adm-a.name` for administration).

4.5.3 Break-glass PROD access is granted only for a logged incident or an approved change, expires within 8 hours [TO CONFIRM], and is reviewed afterwards by the Information Security Department.

4.6 Service Accounts and Machine Identities

4.6.1 Service accounts must be dedicated to one application and one environment, non-interactive, and granted only the permissions that application needs. Database service accounts must not be owners or superusers.

4.6.2 Prefer managed identities (e.g. cloud workload identities) over stored credentials. Where credentials are unavoidable, they must be held in the approved vault (Section 6.4).

4.7 Access Reviews

4.7.1 All vendor access is reviewed at least annually, and privileged access at least every 6 months, with the system owner. The vendor must confirm or revoke each account within 5 working days of the review request.

4.7.2 Dormant accounts (no logon for 45 days [TO CONFIRM]) will be disabled.

5 DATA SECURITY, HANDLING AND PRIVACY

Location data is rarely harmless. A single coordinate can be a customer's home, and a sequence of coordinates reveals a person's routine. Vendors must treat geospatial data at the classification of the most sensitive thing it can reveal.

5.1 Classification Levels

5.1.1 All data must be classified at creation or receipt by the Business Owner. If a dataset has no classification, the vendor must treat it as **Confidential** until told otherwise.

5.1.2 The Company uses four levels [TO CONFIRM level names against the Classification & Handling Procedure]:

Level	Meaning	Typical GIS examples
Public	Approved for public release. No harm if disclosed.	Published post office and branch locations, public basemaps, published service-area maps.
Restricted	Internal use. Limited harm if disclosed.	Internal zoning and sorting-area boundaries, non-personal operational statistics, project documentation.
Confidential	Significant harm, or contains personal data.	Customer addresses and geocoded delivery points, courier GPS tracks, delivery routes, Instant Cash customer and branch transaction locations, logs, source code.
Secret	Severe harm; business-critical or security-sensitive.	Cash-in-transit routes and schedules, vault and data-centre locations, security system layouts, bulk personal datasets, cryptographic keys and credentials.

5.1.3 **Aggregation raises classification.** Combining datasets can create a higher classification than any input. Example: a Restricted list of delivery zones joined with Confidential customer addresses produces at least a Confidential output. A complete national address-to-person dataset is Secret.

5.2 Handling Rules by Level

Control	Public	Restricted	Confidential	Secret
Label on documents, exports and datasets	Optional	Required	Required	Required
Encryption in transit	TLS 1.2+	TLS 1.2+	TLS 1.2+	TLS 1.2+ (TLS 1.3 preferred), mutual TLS between services
Encryption at rest	Not required	Required	Required	Required, with Company-managed keys
Allowed in DEV / TEST	Yes	Yes	Masked or synthetic only (5.5)	Never
Email transfer	Yes	Company email only	Encrypted, with business justification	Prohibited; use approved secure transfer
Export or download by vendor	Yes	Approval of Business Owner	Written Business Owner approval, logged	Prohibited unless approved by the Director of Information Security
Anonymous (unauthenticated) service access	Allowed	Prohibited	Prohibited	Prohibited

5.3 Encryption and Key Management

5.3.1 All network traffic carrying Company data must use TLS 1.2 or higher, including internal traffic between GIS server, database, tile cache and APIs. SSL, TLS 1.0 and TLS 1.1 are prohibited. Plain HTTP is allowed only to redirect to HTTPS.

5.3.2 Data at rest must be encrypted with AES-256 or an equivalent Company-approved algorithm [TO CONFIRM against Minimum Security Baseline]. This includes databases, file shares holding datasets, object storage, tile caches, backups and exported files.

5.3.3 Proprietary or home-made encryption is prohibited. Only standard, vetted cryptographic libraries may be used.

5.3.4 Keys and certificates must be generated, stored and rotated in the approved key vault or HSM. Keys must never be stored in source code, configuration files or container images. Certificates must be issued by a Company-approved certificate authority; self-signed certificates are prohibited outside DEV.

5.4 Personal Data and Privacy by Design

5.4.1 **Data minimisation.** Collect and store only the location attributes the approved purpose needs. Example: a delivery-density heat map needs aggregated counts per area, not individual customer points.

5.4.2 **Precision reduction.** Where exact location is not needed, reduce it before storage or publication. Default: round published coordinates to 3 decimal places (roughly 100 m) or aggregate to a zone, and suppress any area containing fewer than 10 individuals [TO CONFIRM thresholds].

5.4.3 **Tracking data.** Courier and vehicle GPS tracks are personal data of the driver. Tracking must run only during working shifts, must be disclosed to the individuals concerned, and must be retained only for the period the Business Owner has approved.

5.4.4 **Metadata.** Strip EXIF GPS tags and author metadata from photos and documents before publishing them. Remove internal paths, user names and server names from published service metadata and layer descriptions.

5.4.5 **Purpose limitation.** Personal data must be used only for the purpose stated in the work order. Re-use for analytics, model training, demos or marketing is prohibited without written Business Owner and Legal approval.

5.4.6 **Data subject rights.** Systems holding personal data must support locating, exporting, correcting and deleting an individual's records, so the Company can meet PDPL requests.

5.4.7 **Privacy impact assessment.** Any new processing of personal or sensitive personal data requires a privacy assessment approved by Legal and the Information Security Department before build starts.

5.5 Non-Production Data

5.5.1 Production data must not be copied to DEV, TEST or UAT without written approval from the Business Owner and the Information Security Department.

5.5.2 Where approved, data must be masked first. For geospatial data, masking means both attributes **and** geometry: replace names, phones and IDs with synthetic values, and shift or randomise point locations so they no longer match real addresses.

5.5.3 Synthetic data is the default. Example: generate test addresses on real street segments but with random house numbers and fictitious names.

5.5.4 Secret data is never permitted outside PROD.

5.6 Data Residency and Transfer

5.6.1 All Company data classified Restricted, Confidential or Secret, and all personal data, must be stored and processed in the UAE [TO CONFIRM], including backups, logs, tile caches, disaster-recovery copies and support tooling.

5.6.2 Cloud services may be used only in Company-approved UAE regions (e.g. UAE North / UAE Central) [TO CONFIRM approved providers and regions]. The data location must be agreed in writing before any data is uploaded.

5.6.3 **Sending data to an external service is a transfer.** Calling a public geocoding, routing, mapping or AI service with customer addresses or coordinates sends personal data outside the Company. This is prohibited unless the service is on the approved list in Section 12, the location is approved and a Legal-approved PDPL transfer basis exists.

5.6.4 Remote access from outside the UAE to Confidential or Secret data is a cross-border transfer and needs the approval in Section 3.4.2.

5.7 Retention and Disposal

5.7.1 Every dataset must have a retention period set by the Business Owner. The vendor must implement automated deletion or archival at the end of that period.

5.7.2 At the end of the engagement, the vendor must return or securely delete all Company data, including copies on laptops, backups and tools, within 10 working days [TO CONFIRM], and provide a signed certificate of destruction.

5.7.3 Secure deletion means cryptographic erasure or a recognised media-sanitisation method (e.g. NIST SP 800-88). Moving files to a recycle bin or deleting a database table without dropping backups is not deletion.

6 CODE SECURITY AND SECURE DEVELOPMENT PRACTICES

All code delivered to the Company must meet OWASP ASVS Level 2 and the controls below, whether written by the vendor, generated by a tool or copied from an example.

6.1 Threat Modelling

6.1.1 A threat model is required for the initial design and for every major release, and whenever a new data source, integration, public endpoint or data classification is introduced.

6.1.2 It must include a data-flow diagram, trust boundaries, data classifications per flow, threats (STRIDE or equivalent), and the control mitigating each threat. GIS threat models must specifically cover bulk scraping of features or tiles, location inference about individuals, and abuse of OGC and geoprocessing endpoints.

6.2 Input Validation

All input is untrusted, including files, service parameters and data from partner systems. Validate on the server with allow-lists.

GIS input	Required control
Filter and query parameters (`CQL_FILTER`, `FILTER`, ArcGIS `where=`, OData `$filter`)	Parameterised queries only. Never concatenate user input into SQL or spatial SQL (e.g. `ST_GeomFromText`, `ST_DWithin`). Restrict filters to allow-listed fields and operators. Disable free-text SQL `where` clauses on public services.
Coordinates, bounding boxes, spatial reference IDs	Validate type, range (latitude −90 to 90, longitude −180 to 180), expected SRID and a maximum bounding-box area.
Geometries (WKT, GeoJSON, Esri JSON)	Validate structure; cap vertices per geometry and features per request to prevent resource exhaustion.
Uploaded files (Shapefile ZIP, GeoPackage, KML/KMZ, GML, CSV, GeoTIFF)	Allow-list file types by content, not extension; set size limits; scan for malware; extract archives in an isolated location with path-traversal ("zip slip") protection; process in a sandbox.
XML inputs (KML, GML, WFS/WPS requests, SLD styles)	Disable external entities and DTDs (XXE protection) in every XML parser.
URLs supplied by users (add-data-from-URL, cascaded WMS, print services, remote data stores)	Allow-list destination hosts; block internal and metadata address ranges (e.g. 169.254.169.254) to prevent SSRF.
Expression and scripting engines (label expressions, OGC filter functions, geoprocessing scripts)	Disable evaluation of user-supplied expressions or restrict to a safe subset. Example: GeoServer CVE-2024-36401 allowed remote code execution through OGC filter evaluation.

6.3 Output Encoding and Client Security

6.3.1 Encode all output for its context (HTML, attribute, JavaScript, URL). Feature attributes shown in map pop-ups, tooltips, legends and layer descriptions are a common cross-site scripting (XSS) route and must be encoded or sanitised.

6.3.2 Web clients must implement security headers: `Content-Security-Policy`, `Strict-Transport-Security`, `X-Content-Type-Options: nosniff`, `Referrer-Policy` and `frame-ancestors` (or `X-Frame-Options`). CORS must allow only named origins; `Access-Control-Allow-Origin: *` is prohibited on authenticated or non-Public services.

6.3.3 Error messages shown to users must be generic. Stack traces, SQL errors, server paths and product versions must not be returned. Disable verbose error output in GeoServer, ArcGIS Server and application frameworks in UAT and PROD.

6.4 Secrets Management

6.4.1 Secrets (passwords, API keys, tokens, connection strings, private keys, certificates) must be stored only in the approved vault [TO CONFIRM, e.g. Azure Key Vault or HashiCorp Vault] and retrieved at runtime.

6.4.2 Hard-coded secrets are prohibited anywhere: source code, configuration files, notebooks, scripts, Dockerfiles, IaC, pipeline YAML, ArcGIS `.sde` connection files, QGIS project files and map documents committed to Git.

6.4.3 Client-side map API keys (basemap, geocoding) are public by nature. They must be restricted to named HTTP referrers or app IDs, limited to the minimum APIs, quota-capped, and must never grant access to non-Public data.

6.4.4 A secret that has been committed to a repository, even briefly or in a deleted branch, is compromised. The vendor must rotate it immediately and report it under Section 10.

6.4.5 Secret naming convention: `<env>-<system>-<purpose>`, e.g. `prod-gisportal-postgis-app-password`.

6.5 Third-Party Components and Dependencies

6.5.1 Only components from official sources may be used: vendor sites, official package registries (npm, PyPI, Maven Central, NuGet, conda-forge) or the Company's artefact proxy [TO CONFIRM].

6.5.2 Every component must be actively maintained, licensed for commercial use, and free of known Critical or High vulnerabilities at release. Unsupported versions are prohibited (e.g. end-of-life GeoServer, PostGIS, Python or Node.js releases).

6.5.3 Dependency versions must be pinned with lock files (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes).

6.5.4 New third-party libraries, plug-ins, GIS extensions and SaaS APIs require Company Security Focal Point approval before use.

6.6 API and Service Security

6.6.1 Every API and GIS service must authenticate the caller (Section 4.3), authorise each request (Section 4.4), and apply rate limits per user and per IP.

6.6.2 Limit data per request: set maximum feature counts (e.g. `maxFeatures` / `resultRecordCount` of 1,000 or less for Confidential layers [TO CONFIRM]), disable unrestricted WFS `GetFeature` output of whole layers, and disable bulk export formats on non-Public layers.

6.6.3 Disable what is not used: unused OGC services and operations (e.g. WFS-T, WPS), the ArcGIS REST Services Directory and `GetCapabilities` detail in PROD for non-Public services, sample services, demo pages and test endpoints.

6.6.4 All Internet-facing APIs must sit behind the Company API gateway and web application firewall (Section 7.6).

6.7 Application Security Logging

6.7.1 Applications must log: logon success and failure; access-control failures; privileged actions; data exports and bulk queries; feature edits (who, what, when, before and after for Confidential layers); configuration changes; and input-validation failures.

6.7.2 Logs must include UTC timestamp, user or service identity, source IP, action, object and result. Logs must not contain passwords, tokens, full card numbers or unnecessary personal data. Mask coordinates of personal locations where the log does not need them.

6.7.3 Logs must be forwarded to the Company SIEM in a structured format (e.g. JSON).

6.8 AI-Assisted Coding

6.8.1 Code produced with AI assistants is subject to every requirement in this manual and must be reviewed as if written by a person.

6.8.2 Company code, data, credentials, architecture details and logs must not be entered into public AI tools. Only Company-approved AI tools may be used [TO CONFIRM approved tools].

7 VERSION CONTROL, CI/CD AND DEPLOYMENT SECURITY

7.1 Repositories

7.1.1 All Company source code, IaC, pipeline definitions, database scripts, GIS configuration (service definitions, styles, map projects) and documentation must be held in the Company-owned repository platform [TO CONFIRM, e.g. Azure DevOps or GitHub Enterprise]. The Company owns the repository from the first commit.

7.1.2 Company code must not be stored in personal or vendor-owned repositories, public repositories, gists, forks, pastebins or file-sharing sites.

7.1.3 Repositories must be private, with access by named individual only. Each repository must contain a `.gitignore` excluding secrets, data files (`*.shp`, `*.gpkg`, `*.gdb`, `*.csv` extracts), local connection files (`*.sde`) and environment files (`.env`).

7.1.4 Data must not be committed to Git. Test fixtures may be committed only if they are synthetic and labelled as such.

7.2 Branch Protection

7.2.1 The following settings are mandatory on `main` and every `release/*` branch:

- direct pushes and force pushes blocked, and branch deletion blocked;
- merge only through a pull request;
- at least one approving reviewer who is not the author, and two for changes to authentication, authorisation, cryptography, pipeline or IaC files;
- all pipeline checks in Section 7.4 passing before merge;
- approvals dismissed when new commits are pushed;
- signed commits (GPG, SSH or S/MIME) required.

7.2.2 Branch naming: `feature/<ticket>-<short-name>`, `bugfix/<ticket>-<short-name>`, `hotfix/<ticket>-<short-name>`, `release/<version>`. Example: `feature/GIS-214-parcel-search`.

7.2.3 A `CODEOWNERS` file must name the Vendor Security Lead as a required reviewer for security-relevant paths.

7.3 Code Review

7.3.1 Reviewers must check each pull request against a security checklist covering: input validation (6.2), output encoding (6.3), secrets (6.4), authorisation checks (4.4), logging (6.7) and data exposure in new or changed GIS services.

7.3.2 Reviewers must not approve their own work, and a single person must not both author and approve a production release.

7.4 Mandatory Pipeline Security Gates

7.4.1 Every build must run the following controls automatically. A failed gate blocks the merge or release; gates must not be switched off, skipped or set to "warn only" without an approved exception.

Stage	Required controls	Blocks release when
Commit / pull request	Secret scanning (pre-commit and server side)	Any secret detected
Build	SAST; SCA with 100% dependency coverage; licence check; SBOM generation (CycloneDX or SPDX)	Any Critical or High finding; SCA not completed
Infrastructure as Code	IaC scanning and policy validation against the hardening baseline	Any Critical or High misconfiguration
Containers	Image scanning; approved base images only; non-root user; no secrets in layers	Any Critical or High vulnerability; non-approved base image; runs as root
Test	DAST and API security testing in TEST or UAT; security regression tests	Any Critical or High finding
Release	Artefact signing and signature verification; change approval recorded	Unsigned artefact; no approved change; no security sign-off
Production	Continuous vulnerability scanning and monitoring	Findings handled under Section 8.3

7.4.2 Pipeline evidence (scan reports, SBOM, approvals) must be retained with each release for the period in Section 9.4.

7.5 Pipeline and Release Integrity

7.5.1 Pipeline secrets must come from the vault through short-lived credentials. Pipeline variables must be marked secret and masked in logs.

7.5.2 Build agents must be Company-managed or ephemeral, hardened, and must not be shared with other customers of the vendor.

7.5.3 Only artefacts built by the Company pipeline may be deployed. Manually built packages, images pulled from public registries at deploy time and "hotfixes copied to the server" are prohibited.

7.5.4 Every production deployment must follow the Company change management process with a recorded, approved change, a tested rollback plan and a named implementer.

7.5.5 Emergency changes are allowed only for a logged incident, must still pass the secret, SAST and SCA gates, and must be retrospectively reviewed within 2 working days.

7.6 Hosting and Internet-Facing Deployment

7.6.1 Infrastructure must align with CIS Benchmarks and the ISMS Minimum Security Baseline, with network segmentation between web, application, GIS server and database tiers. Databases must never be directly reachable from the Internet.

7.6.2 Internet-facing GIS applications and services must additionally have: a web application firewall; DDoS protection; the Company API gateway with authentication and rate limiting; bot protection for public map and search endpoints; EDR on all servers; and continuous external attack surface monitoring.

7.6.3 Public tile caches and CDNs may hold only Public data.

7.7 Audit Logging of the Delivery Chain

7.7.1 Audit logs must be enabled for the repository platform, CI/CD, artefact registry, vault and cloud control plane, and forwarded to the Company SIEM. Logs must record who changed branch protection, pipeline definitions, secrets, permissions and deployments.

7.7.2 The vendor must not disable, alter or delete audit logs.

8 SECURITY TESTING AND VULNERABILITY MANAGEMENT

8.1 Required Testing

Test	When	Performed by	Evidence
SAST, SCA, secret scan, IaC and container scans	Every build	Vendor pipeline	Pipeline reports, SBOM
DAST and API security testing	Every release to UAT	Vendor	Scan report with all findings and dispositions
ASVS Level 2 verification	Before first go-live and every major release	Vendor, reviewed by Company	Completed ASVS checklist with evidence per control
Security regression tests	Every release	Vendor	Test results for previously fixed issues
VAPT	Before first go-live, after significant change, and annually for Internet-facing systems	Company Information Security or a Company-appointed independent tester	VAPT report and retest report
Continuous vulnerability scanning	Continuous in PROD	Company	Scanner dashboard, tracked tickets

8.1.1 A **significant change** includes: a new Internet-facing endpoint; a new authentication or authorisation method; a new data source classified Confidential or Secret; a major version upgrade of the GIS platform or database; or a hosting change.

8.1.2 DAST and API tests must cover GIS endpoints explicitly: OGC services, feature and map service query operations, geocoding, routing, geoprocessing, print and export services.

8.2 Rules of Engagement

8.2.1 The vendor may run security scans only against DEV, TEST and UAT environments it is contracted to build. Scanning or testing PROD, shared Company infrastructure or any third party requires prior written authorisation from the Information Security Department.

8.2.2 The vendor must not use production data as test payloads, and must not attempt to bypass Company security controls (WAF, EDR, PAM, network restrictions) to make a test pass.

8.3 Severity and Remediation Deadlines

8.3.1 Findings are rated with CVSS v3.1 or later, adjusted by the Company for data classification and exposure. The Company's rating is final.

Severity	CVSS	Before go-live	In production: fix and deploy within [TO CONFIRM]
Critical	9.0–10.0	Must be fixed	7 calendar days (48 hours if actively exploited, or Internet-facing with a public exploit)
High	7.0–8.9	Must be fixed	30 calendar days
Medium	4.0–6.9	Fixed or exception approved	90 calendar days
Low	0.1–3.9	Tracked	180 calendar days or next major release

8.3.2 Deadlines run from the time the vendor is notified or the finding is first reported by a tool, whichever is earlier.

8.3.3 A finding is closed only when the fix is deployed and verified by retest. "Accepted" is valid only as an approved exception under Section 2.4.

8.3.4 The vendor must not release while any Critical or High finding is open, unless an approved exception covers it.

8.4 Internet-Facing Systems

8.4.1 Internet-facing GIS applications must pass an independent third-party VAPT before go-live and at least annually, and after every significant change.

8.4.2 All Critical and High findings must be remediated and retested before go-live.

8.5 Patching

8.5.1 The vendor must monitor security advisories for every component it delivers (e.g. Esri security patches, GeoServer, GeoNetwork, PostGIS, OpenLayers, Leaflet, application frameworks, base images).

8.5.2 The vendor must notify the Company Security Focal Point of any relevant Critical or High advisory **within 2 working days** of publication, with an impact assessment and remediation plan.

8.5.3 Security patches follow the deadlines in 8.3.1 and the change process in 7.5.4.

8.6 Vulnerability Disclosure by the Vendor

8.6.1 The vendor must report to the Company any vulnerability it finds in Company systems, including in components it did not build, within 1 working day. The vendor must not disclose Company vulnerabilities to any other party.

9 COMPLIANCE AND REGULATORY REQUIREMENTS

9.1 Applicable Laws, Regulations and Standards

9.1.1 The vendor must comply with the following in all work for the Company. The Company's Legal Department is the authority on their interpretation.

Instrument	What it means for GIS vendors
Federal Decree-Law No. 45 of 2021 (PDPL)	Lawful processing, minimisation, security, cross-border transfer rules and breach notification for personal data, including location data (Sections 5.4, 5.6, 10).
UAE Information Assurance Regulation v1.1	National baseline of management (M1–M6) and technical (T1–T9) controls; mapped in 9.2.
Federal Decree-Law No. 34 of 2021 (Combatting Rumours and Cybercrimes)	Unauthorised access, data interception and misuse of systems are criminal offences.
Federal Decree-Law No. 46 of 2021 (Electronic Transactions and Trust Services)	Requirements for electronic records, signatures and trust services where the solution uses them.
Dubai Law No. 26 of 2015 (Data Dissemination and Exchange)	Rules on classification and sharing of data exchanged with Dubai government entities.
Federal Law No. 7 of 2002 (Copyright)	Software, datasets, basemaps and imagery must be properly licensed (Section 9.6).
ISO/IEC 27001:2022	The Company ISMS. Vendor controls are in scope of Company ISMS audits.
OWASP ASVS v5.0 (Level 2), OWASP SAMM, OWASP DevSecOps Guideline	Application security verification and secure development baseline.
Sector requirements [TO CONFIRM]	E.g. Central Bank of the UAE requirements where Instant Cash systems or data are in scope.

9.2 UAE Information Assurance Regulation Mapping

This manual	UAE IAR controls
Section 2.3 (Secure SDLC) and 6.1 (Threat modelling)	T7.1, T7.2.1 Security requirements
Section 4 (Identity and access)	T5 Access Control
Sections 5.1–5.2 (Classification and handling)	T1 Asset Management
Section 5.3 (Encryption and keys)	T7.4.1 Use of cryptographic controls, T7.4.2 Key management, T4 Communications
Section 5.5 (Non-production data)	T7.5.2 Protection of system test data
Sections 6.2–6.3 (Input and output validation)	T7.3.1 Input data validation, T7.3.2 Control of internal processing, T7.3.3 Message integrity, T7.3.4 Output data validation
Section 6.5 (Third-party components)	T7.6.3 Restrictions on changes to software packages, T7.8 Supply chain protection
Section 7.1 (Repositories)	T7.5.3 Access control to program source code
Section 7.5 (Release and change)	T7.5.1 Control of operational software, T7.6.1 Change control, T7.6.2 Technical review of applications
Sections 5.4 and 6.6.2 (Data exposure)	T7.6.4 Information leakage
Sections 6.7 and 7.7 (Logging)	T3 Operations Management
Section 8 (Vulnerability management)	T7.7.1 Control of technical vulnerabilities
Section 10 (Incidents)	T8 Information Security Incident Management
Section 11 (Vendor accountability)	T6 Third-Party Security, T7.6.5 Outsourced software development, M3 Awareness and Training

9.3 Personal Data Obligations

9.3.1 The vendor acts as a processor on the Company's documented instructions. It must not decide the purpose or means of processing.

9.3.2 The vendor must sign the Company's data processing terms before receiving any personal data.

9.3.3 Personal data must not be transferred outside the UAE without a Legal-approved PDPL transfer basis and written Company approval.

9.3.4 The vendor must assist the Company, within 5 working days of request [TO CONFIRM], with data subject requests, privacy assessments and regulator enquiries.

9.4 Audit Trails and Retention

Record	Minimum retention
Security, application, system and audit logs	6 months, of which the most recent 30 days are online and searchable
Backup data	6 months
Backup and restoration job logs	6 months (the longer of backup and log retention applies)
Pipeline evidence per release (scan reports, SBOM, approvals, sign-offs)	Life of the system plus 1 year [TO CONFIRM]
VAPT reports and retest evidence	3 years [TO CONFIRM]
Access requests, approvals and reviews	3 years [TO CONFIRM]
Security exceptions	Life of the exception plus 3 years [TO CONFIRM]
Incident records and evidence	5 years [TO CONFIRM]

9.4.1 A longer period applies whenever required by law, regulation, contract or an open investigation or legal case. Logs under legal hold must be preserved until the case is closed.

9.4.2 Logs are Confidential. They must be protected from alteration and deletion, and access to them must itself be logged.

9.5 Audit and Compliance Monitoring

9.5.1 The Company, its Internal Audit function, external certification bodies and regulators may audit the vendor's compliance with this manual, with reasonable notice, or immediately where a regulator requires it.

9.5.2 The vendor must provide requested evidence within 5 working days, and must grant access to relevant personnel, facilities, systems and subcontractors.

9.5.3 Every non-compliance is recorded as a finding with a named owner and due date, and tracked to closure.

9.6 Licensing and Intellectual Property

9.6.1 All software, plug-ins, fonts, basemaps, imagery and third-party datasets must be properly licensed for the Company's use. Unlicensed or "trial" software in delivered solutions is prohibited.

9.6.2 The vendor must respect third-party data licence terms. Example: some basemap and imagery licences prohibit caching, offline storage or derivative datasets.

9.6.3 The vendor must maintain an inventory of all licences and open-source components (the SBOM satisfies this for code components).

10 INCIDENT RESPONSE AND ESCALATION

10.1 What Must Be Reported

10.1.1 The vendor must report every actual or suspected Security Incident affecting Company information, systems, code or environments, including those in the vendor's own systems or subcontractors. Report first, investigate second. A report that turns out to be a false alarm is never penalised; a late report is a breach.

10.1.2 Examples that must be reported:

- a secret, token or key committed to a repository, pasted into a chat or ticket, or otherwise exposed;
- a lost or stolen device used for Company work;
- Company data found in an unapproved location (personal drive, public repository, public AI tool, unapproved cloud service);
- a GIS service found to expose non-Public data anonymously, or unexpected bulk downloads of features or tiles;
- malware on any device or server used for Company work;
- unauthorised access or suspicious activity in repositories, pipelines, servers or GIS platforms;
- compromise of the vendor's own network, identity platform or a supplier in its chain;
- any breach of personal data.

10.2 Reporting Deadlines and Severity

Severity	Examples	Initial report to the Company	Written update
Critical	Confirmed personal data breach; confirmed compromise of PROD; ransomware; exposed PROD credentials	Within 1 hour of detection, by phone and email [TO CONFIRM]	Every 4 hours until contained
High	Suspected breach; exposed non-PROD secret; lost unencrypted device; Confidential data in an unapproved location	Within 4 hours of detection [TO CONFIRM]	Daily until closed
Medium / Low	Policy violation without data exposure; blocked malware; failed attack attempts	Within 1 working day	At closure

10.2.1 Report to: Company Security Operations / Information Security Department at [TO CONFIRM mailbox and 24x7 phone number], copying the Company Security Focal Point.

10.2.2 The initial report must state: what happened; when it was detected; systems, data and classifications affected; the number of individuals affected if known; actions already taken; and a vendor contact available 24x7.

10.3 Vendor Actions During an Incident

(i) **Contain** immediately where it is safe to do so: revoke or rotate exposed credentials, isolate affected devices, disable an exposed service.

(ii) **Preserve evidence.** Do not wipe, re-image, delete logs or rewrite Git history without Company approval.

(iii) **Follow Company direction.** The Company Information Security Department leads the response. The vendor must make qualified staff available within 2 hours, 24x7, for Critical and High incidents.

(iv) **Do not communicate externally.** Only the Company notifies regulators, data subjects, customers, partners or media. The vendor must not contact any of them about a Company incident unless required by law, and then only after informing the Company.

(v) **Remediate** the root cause within the agreed timeframe.

(vi) **Report.** Deliver a written root-cause report within 5 working days of containment, including timeline, root cause, impact and corrective actions.

10.4 Regulatory Notification

10.4.1 The Company decides and performs all notifications to the UAE Data Office, TDRA and other authorities under the PDPL and the UAE IAR. The vendor's early report is what makes the Company's deadlines achievable; delay by the vendor is treated as a serious breach.

10.5 Escalation

10.5.1 If the vendor receives no acknowledgement within 30 minutes of a Critical report, it must escalate to the Project Manger "PM", Director of Information Security [TO CONFIRM escalation contact].

10.5.2 The vendor must participate in the Company's incident response exercises when invited, and at least once a year for Internet-facing systems.

11 VENDOR RESPONSIBILITIES AND ACCOUNTABILITY

11.1 Contractual Standing

11.1.1 Compliance with this manual is a condition of the contract. The vendor is accountable for every person and subcontractor working on its behalf.

11.1.2 The vendor must hold, and evidence at onboarding and annually, a recognised security certification or attestation relevant to the services (e.g. ISO/IEC 27001 certificate or SOC 2 Type II report). Where it has none, it must complete the Company's third-party security assessment.

11.2 Vendor Security Lead

11.2.1 The Vendor Security Lead must:

(i) maintain the list of vendor personnel with access, and their roles;
(ii) ensure every gate in Sections 2.3 and 7.4 is met, and hold the evidence;
(iii) submit exception requests and track remediation of findings;
(iv) report incidents under Section 10;
(v) deliver the monthly security status report (11.5);
(vi) be the single point of contact for security audits.

11.3 Onboarding of Personnel

11.3.1 Before any person receives access, the vendor must confirm in writing that the person has:

- signed the Company non-disclosure agreement and acknowledged this manual and the Company Acceptable Use Policy;
- passed background screening appropriate to the data they will access [TO CONFIRM screening standard];
- completed Company-approved security awareness training, and secure coding training for developers (repeated annually);
- been approved by the Business Owner for a named role and a defined period.

11.4 Subcontractors

11.4.1 Subcontracting any part of the work that involves Company data, code or systems requires prior written Company approval.

11.4.2 The vendor must flow down every requirement of this manual to approved subcontractors and remains fully liable for them.

11.5 Reporting and Evidence

11.5.1 The vendor must deliver a monthly security status report containing: personnel with access (joiners, movers, leavers); open findings by severity and age; pipeline gate results; open exceptions and their expiry; incidents; and upcoming changes that may be significant (8.1.1).

11.5.2 Before each production release, the vendor must deliver an evidence pack: pipeline reports, SBOM, ASVS checklist (where required), test reports, open findings with dispositions, and the approved change record.

11.6 Handover and Exit

11.6.1 At the end of the engagement, the vendor must: hand over all source code, IaC, pipeline definitions, documentation, and secrets inventories (names and locations only, never values); support rotation of every credential it has known; return all Company assets; and delete Company data under Section 5.7.

11.6.2 Confidentiality obligations survive the end of the contract.

11.7 Consequences of Non-Compliance

11.7.1 Depending on severity, the Company may, without prejudice to its other contractual rights:

- withhold acceptance of deliverables or payment milestones until findings are closed;
- suspend or revoke access for individuals or the whole vendor team;

- require removal of specific personnel from the engagement;
- require remediation at the vendor's cost, including independent re-testing;
- apply contractual penalties, recover costs arising from an incident, or terminate the contract;
- refer matters to the authorities where UAE law may have been breached.

12 APPROVED TOOLS AND TECHNOLOGY RESTRICTIONS

12.1 General

12.1.1 Only tools listed as approved below, or approved in writing by the Information Security Department, may touch Company code, data or environments. A tool not on the list is not approved.

12.1.2 Requests for additions must be made through the Company Security Focal Point, stating the tool name, version, hosting location, data it will access and licence.

12.2 Approved Tool Categories

[TO CONFIRM: the specific products below are draft defaults pending the Company's approved-software list.]

Category	Approved (draft)	Notes
Source control and CI/CD	Company Azure DevOps or GitHub Enterprise tenant	Company-owned organisation only.
Secrets vault	Azure Key Vault or HashiCorp Vault (Company instance)	No secrets in pipeline variables without vault reference.
Secret scanning	Gitleaks; platform-native secret scanning	Pre-commit hook and server-side.
SAST	SonarQube (Company instance), Semgrep	Quality gate configured to block Critical/High.
SCA and SBOM	OWASP Dependency-Check, Dependabot, Syft (CycloneDX output)	100% dependency coverage.
IaC scanning	Checkov, tfsec / Trivy config	Policies aligned to the hardening baseline.
Container scanning and signing	Trivy; Sigstore cosign	Approved base images from the Company registry.
DAST and API testing	OWASP ZAP, Burp Suite Professional	TEST/UAT only unless authorised (8.2).
Company VAPT toolset	Nmap, OWASP ZAP, Burp Suite, Acunetix	Operated by Company or Company-appointed testers.
GIS platforms	Esri ArcGIS Enterprise; GeoServer; PostgreSQL/PostGIS; QGIS (desktop) [TO CONFIRM project stack]	Supported versions only; hardened per 3.3.
Web mapping libraries	ArcGIS Maps SDK for JavaScript, OpenLayers, Leaflet, MapLibre GL	Maintained versions only; covered by SCA.
AI coding assistants	Company-approved tools only [TO CONFIRM]	Subject to 6.8.

12.3 Prohibited Without Explicit Written Approval

Prohibited	Why	Use instead
Public geocoding, routing, mapping or AI APIs called with customer addresses or coordinates (e.g. public Google Maps, OpenStreetMap Nominatim, public LLM chat tools)	Transfers personal data outside the Company and often outside the UAE (5.6.3)	Company-hosted geocoder or approved service in an approved region
Public sharing features: ArcGIS Online "share with everyone", Google My Maps, public Mapbox styles, Felt, public Kaggle or Hugging Face datasets	Publishes Company data to the Internet	Company portal with role-based sharing
Personal or vendor-owned repositories, cloud drives, email accounts and messaging apps for Company code or data	Loss of Company control and audit trail	Company repository and collaboration tenant
Pastebins, online JSON/GeoJSON/WKT viewers and converters, online "shapefile to GeoJSON" sites	Uploads data to unknown third parties	Local, approved tools (QGIS, GDAL/ogr2ogr)
Remote access and tunnelling tools (AnyDesk, TeamViewer, ngrok)	Bypasses Company access controls	Company remote access with MFA and PAM
Unsupported or end-of-life software and components	Unpatched vulnerabilities	Current supported releases
Cracked, unlicensed or trial software in deliverables	Legal and malware risk	Licensed software
Unapproved browser extensions and IDE plug-ins with network access on devices used for Company work	Can read source code and credentials	Approved extensions only
Removable storage media	Data loss	Approved secure file transfer
Cryptocurrency miners, hacking tools or traffic interception tools on Company networks	Misuse of facilities; possible criminal offence	Authorised testing tools under 8.2 only

13 VENDOR FREQUENTLY ASKED QUESTIONS

Question	Answer
Can we use a copy of production data to reproduce a bug?	Not by default. Use synthetic data. If production data is essential, request approval (5.5.1); if approved, it must be masked, including geometry, and deleted after use. Secret data never leaves PROD.
Can our offshore team work on the project?	Only with prior written approval from the Information Security Department (3.4.2), and never with access to Confidential or Secret data without a PDPL transfer basis (5.6).
Can we use our own GitHub organisation and transfer the code at the end?	No. Code lives in the Company repository from the first commit (7.1.1).
Is a basemap API key in the JavaScript a hard-coded secret?	It is unavoidable, so it is allowed only if referrer-restricted, API-scoped, quota-capped and unable to reach non-Public data (6.4.3). Server-side keys and tokens must always come from the vault.
Can we geocode customer addresses with a public API during testing?	No. That is a transfer of personal data (5.6.3). Use synthetic addresses or the Company-approved geocoder.
The layer is hidden in the web map, so users can't see it. Is that enough?	No. The service must enforce access itself (4.4.1). Anyone can call the REST or OGC endpoint directly.
A High finding is in a library we can't upgrade before the go-live date. Can we release?	Only with an approved exception (2.4) that names compensating controls and an expiry date. Otherwise the release is blocked (8.3.4).
Can we temporarily set a pipeline gate to "warn only" to meet a deadline?	No, not without an approved exception (7.4.1). Changes to pipeline settings are audited (7.7).
Do these rules apply to DEV?	Yes. DEV uses the same hardening baseline, no production data, MFA and no Internet-exposed admin consoles (3.3).
Can we use AI assistants to write code?	Only Company-approved tools, never with Company data or secrets in the prompt, and the output is reviewed and scanned like any other code (6.8).
We accidentally pushed a password and deleted the commit a minute later. Do we need to report it?	Yes. Treat the secret as compromised, rotate it immediately and report it (6.4.4, 10.1.2).
Who decides a dataset's classification?	The Company Business Owner. Until you are told, treat it as Confidential (5.1.1).
Can we publish a public map of deliveries for marketing?	Only aggregated, precision-reduced data approved as Public by the Business Owner (5.4.2), served from a Public-only cache (7.6.3).
Who talks to the regulator if there is a breach?	The Company only. Report to the Company fast and do not contact external parties (10.3, 10.4).

ANNEX A – GIS GO-LIVE SECURITY CHECKLIST

The vendor must complete every item and attach evidence before requesting security sign-off (2.3.1).

- ☐ Data classified by the Business Owner for every dataset, layer and service (5.1)
- ☐ Privacy assessment approved where personal data is processed (5.4.7)
- ☐ Threat model completed and reviewed (6.1)
- ☐ Architecture security review completed (2.3.1)
- ☐ Environments segregated; no production data outside PROD without approval (3.1, 5.5)
- ☐ Default accounts removed; admin consoles not reachable from the Internet (3.3.2, 3.3.3)
- ☐ SSO and MFA in place; server-side authorisation at layer, feature and field level (4.3, 4.4)
- ☐ Editing and unused OGC operations disabled; feature limits set (4.4.4, 6.6.2, 6.6.3)
- ☐ TLS 1.2+ everywhere; encryption at rest; keys in vault (5.3)
- ☐ Data residency confirmed for data, backups, logs and caches (5.6)
- ☐ No hard-coded secrets; client API keys restricted (6.4)
- ☐ ASVS Level 2 compliance verified (1.2)
- ☐ SAST, SCA, secret, IaC and container scans passed; SBOM produced (7.4)
- ☐ DAST and API security testing completed (8.1)
- ☐ VAPT completed; all Critical and High findings closed and retested (8.3, 8.4)
- ☐ Security headers, WAF, API gateway, rate limiting and bot protection in place for Internet-facing services (6.3.2, 7.6.2)
- ☐ Application and platform logs flowing to SIEM (6.7, 7.7)
- ☐ Backup and restore tested; business continuity requirements validated (9.4)
- ☐ Approved change record and rollback plan (7.5.4)
- ☐ Open exceptions registered with expiry dates (2.4)
- ☐ Security sign-off issued by the Information Security Department (2.3.1)

ANNEX B – OPEN ITEMS TO CONFIRM BEFORE ISSUE

These items are for the Information Security Department and are removed from the vendor-issued version.

#	Item	Section	Draft value used
1	ISMS Minimum Security Baseline content: the file received is protected with Microsoft Information Protection and could not be read	3.3, 4.2, 5.3, 7.6	Referenced by name only; technical values drafted
2	Official classification level names (policy text uses Confidential/Secret; the header says Restricted; the footer says EIA Highly Confidential)	5.1	Public / Restricted / Confidential / Secret
3	Data residency rule and approved cloud providers and regions	5.6	UAE-only for Restricted and above; UAE North / UAE Central
4	Whether offshore development and remote access from outside the UAE are allowed	3.4.2	Prior written approval required
5	Vendor access model (Company laptop, VDI, jump host, PAM product)	3.2.1, 4.5	Any of the three, with PAM for UAT/PROD
6	Identity provider and MFA methods	4.2, 4.3.1	Entra ID; MFA for all vendor access
7	Password length for vendor and privileged accounts (Company policy minimum is 8)	4.2.2	14 characters
8	Session, token, lock-screen, break-glass and dormancy values	3.2.2, 4.3.3, 4.3.5, 4.5.3, 4.7.2	10 min lock; 60 min tokens; 15 min admin idle; 8 h break-glass; 45 days dormant
9	Vendor account maximum validity and leaver notice	4.1.3, 4.1.4	6 months; 1 working day
10	Encryption at rest algorithm	5.3.2	AES-256
11	Location precision and small-count suppression thresholds; feature limits per request	5.4.2, 6.6.2	3 decimals; suppress fewer than 10; 1,000 features
12	Repository platform, vault, artefact proxy, approved tool list and GIS stack	6.4.1, 6.5.1, 7.1.1, 12.2	As listed in 12.2
13	Approved AI coding tools	6.8.2	None named
14	Vulnerability remediation deadlines in production	8.3.1	7 / 30 / 90 / 180 days
15	Incident reporting deadlines, mailbox, 24x7 number and escalation contact	10.2, 10.5	1 h / 4 h / 1 working day
16	Retention for pipeline evidence, VAPT, access records, exceptions and incidents	9.4	As listed in 9.4
17	Data return and deletion deadline; data subject request support deadline	5.7.2, 9.3.4	10 and 5 working days
18	Background screening standard for vendor personnel	11.3	Not specified
19	Entities in scope and any sector regulation (e.g. CBUAE for Instant Cash)	1.3.1, 9.1	All five entities; sector rules flagged
20	Approval authority for this manual	Document Control	Director of Information Security;